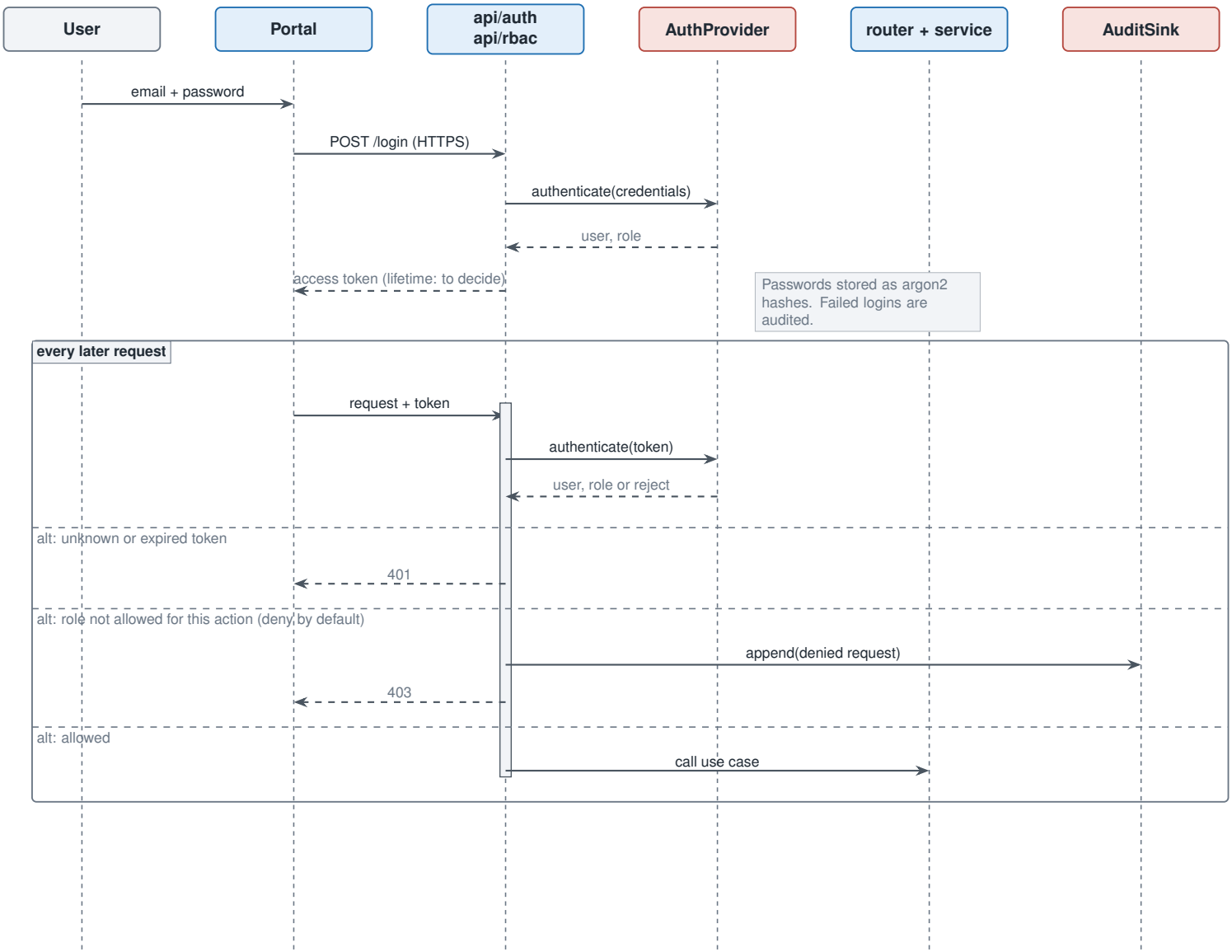
Authenticate, authorise, then act; refusals are audited too

Level 04 - sequence: sign-in and request guard. The portal hides what the API would refuse, but only the API decides.



Test required by the report: a matrix over every role and action; every unauthorised request is rejected by the backend. Token lifetime and refresh are decisions for sprint 1 and are not stated in the report.